Федеральное государственное бюджетное образовательное учреждение
высшего профессионального образования
«Казанский национальный исследовательский технологический университет»
Кафедра информатики и прикладной математики

ИНФОРМАЦИОННО-КОММУНИКАЦИОННЫЕ СИСТЕМЫ И СЕТИ

ЛАБОРАТОРНАЯ РАБОТА №9.
БЕЗОПАСНОСТЬ В СЕТЯХ

Методические указания к лабораторной работе

Казань
КНИТУ
2013

Цель работы: Ознакомиться с принципами безопасного функционирования сети, сетевыми угрозами и способами их выявления и предотвращения. Получить практический навык по конфигурированию межсетевых экранов и настройке демилитаризованной зоны.

Риски вторжения в сеть

Компьютерные сети – как проводные, так и беспроводные – стремительно приходят в повседневную жизнь. Индивидуальные пользователи и организации в равной мере зависят от надежной работы компьютеров и сетей в таких задачах, как электронная почта, учет, организационное управление и работа с файлами. Несанкционированное вторжение в сеть может привести к чрезвычайно затратным перебоям и потере ценных результатов работы. Атака на сеть может иметь разрушительные последствия с потерей времени и денег в результате повреждения или хищения важной информации и ресурсов.

Злоумышленники могут получить доступ в сеть, эксплуатируя уязвимости в ПО, атакуя оборудование или даже используя такие приемы, как угадывание чужого имени пользователя и пароля.

Злоумышленник, получивший доступ в сеть, сразу становится источником четырех видов угроз.

1. *Хищение информации* – проникновение в компьютер для получения конфиденциальных сведений. Эта информация может быть использована или продана с различными целями. Пример: хищение конфиденциальной информации, принадлежащей организации, например, данных о научно-технических разработках.

2. *Хищение персональных данных* – вид хищения информации, при котором крадутся личные данные для использования с целью обмана. Злоумышленник, завладевший персональными данными, может получить юридические документы, подать заявление на кредит и совершать несанкционированные покупки через интернет. Проблема хищения персональных данных продолжает обостряться, а финансовые потери составляют миллиарды долларов в год.

3. *Потеря данных и манипуляции с данными* – проникновение в компьютер с целью уничтожения или изменения данных. Примеры потери данных: передача вируса, форматирующего жесткий диск компьютера. Примеры манипуляций с данными: проникновение в систему хранения информации с целью изменения каких-либо данных, например, цены изделия.

4. *Прекращение обслуживания* – лишение зарегистрированных пользователей возможности доступа к услугам, которыми они имеют право пользоваться. Пример: DoS-атаки (отказ в обслуживании), целью которых становятся серверы, сетевые устройства и сетевые каналы связи

Источники вторжения

Угроза вторжения в сеть исходит от злоумышленников, расположенных как внутри, так и за пределами организации.

Внешние угрозы исходят от лиц, находящихся за пределами организации и не обладающих санкционированным доступом к компьютерным системам и сетям. Злоумышленники проникают в сеть извне, главным образом – из интернета, по беспроводным каналам и через серверы коммутируемого доступа.

Внутренние угрозы исходят от пользователей, имеющих официально разрешенный доступ в сеть с учетной записью или физический доступ к сетевому оборудованию. Злоумышленники, атакующие сеть изнутри, знакомы с внутренней политикой и персоналом. Кроме того, они обычно знают, какая информация представляет ценность и наиболее уязвима, а также владеют сведениями о том, как получить к ней доступ.

В то же время, не все внутренние атаки являются преднамеренными. В некоторых случаях внутренняя угроза исходит от добросовестного сотрудника, который, находясь за пределами компании, стал жертвой вируса или нарушения безопасности и впоследствии неосознанно принес эту угрозу во внутреннюю сеть.

Многие компании затрачивают значительные ресурсы на защиту от внешних атак, при том, что подавляющее большинство атак имеют внутреннюю

природу. Согласно данным ФБР США, внутренний доступ и нарушение регламента пользования компьютерными системами – причина 70% известных нарушений в области информационной безопасности.

Для злоумышленника одним из простейших способов получения доступа как изнутри, так и извне является манипуляция людьми. Так, например, известный хакер Кевин Митник, осужденный в 1995 г. за нанесение ущерба общей суммой свыше 80 миллионов долларов, получал доступ к защищенным системам именно с помощью манипуляции.

Широко распространена практика эксплуатации психологических слабостей, называемая социотехникой.

Социотехника (*социальный инжиниринг*) – использование внешних факторов для влияния на поведение группы людей. В контексте компьютерной и сетевой безопасности под социотехникой понимаются различные приемы введения в заблуждение внутренних пользователей с подталкиванием к выполнению определенных действий или разглашению конфиденциальной информации. В результате злоумышленник через ничего не подозревающих внутренних пользователей получает доступ к внутренним ресурсам и личным данным, например, банковским реквизитам и паролям. Социотехника – распространенный фактор опасности, предполагающий эксплуатацию психологических слабостей для получения требуемых результатов.

Три наиболее распространенных приема социотехники: вымышленный предлог, фишинг и вишинг.

Вымышленный предлог – способ получения конфиденциальной информации, при котором для введения жертвы в заблуждение используется вымышленный сценарий, побуждающий разгласить информацию или выполнить определенное действие. Контакт с жертвой обычно осуществляется по телефону. Прием эффективен в том случае, если злоумышленнику удается завладеть доверием жертвы. Злоумышленник во многих случаях изначально должен распо-

лагать некоторыми знаниями или наблюдениями. Например, если ему известен номер счета жертвы, он может воспользоваться этой информацией для вхождения в доверие. После этого выудить дополнительную информацию будет проще.

Фишинг (англ. *fishing*, рыбалка) – способ добычи конфиденциальных данных путем маскировки под легитимный источник. Контакт с жертвой обычно происходит по электронной почте. Злоумышленник может обратиться с просьбой уточнить определенные реквизиты, например пароли или имена пользователей, во избежание нежелательных последствий.

Вишинг – способ добычи конфиденциальной информации посредством *IP*-телефонии. Жертва получает сообщение голосовой почты с указанием перезвонить на номер, принадлежащий легитимной службе банковского самообслуживания. Однако разговор перехватывается мошенником. В итоге в его распоряжении оказываются номера банковских счетов и пароли, сообщаемые по телефону для проверки.

Помимо социотехники существуют и другие виды атак, которые направлены уже на уязвимости в компьютерном ПО. К ним относятся вирусы, черви и «троянские кони». Их общим свойством является проникновение вредоносного ПО на узел. Вредоносное ПО может вывести из строя систему, уничтожить данные и нарушить доступ к сетям, системам и службам. Кроме того, незаметно для пользователей оно может привести к попаданию важной информации и личных данных в руки преступников. Во многих случаях вредоносные программы самопроизвольно распространяются по другим узлам сети.

Иногда эти технологии используются параллельно с социотехникой: ничего не подозревающим пользователем манипулируют так, что он становится инициатором атаки.

Вирус – программа, которая функционирует и распространяется путем изменения других программ и файлов. Вирус не запускается сам, он должен быть тем или иным образом активирован пользователем. После активации действия вируса могут ограничиться простым размножением и распространением. Одна-

ко даже такие вирусы опасны, поскольку они способны быстро заполнить всю свободную память и сильно замедлить или даже парализовать работу системы. Более серьезные вирусы могут быть запрограммированы на удаление или повреждение конкретных файлов перед дальнейшим распространением. Вирусы могут распространяться через вложения в электронной почте, загружаемые из интернета файлы, системы мгновенного обмена сообщениями, а также через дискеты, компакт-диски и *USB*-устройства.

Червь аналогичен вирусу с тем отличием, что ему не требуется внедряться в существующую программу. Червь самостоятельно рассылает собственные копии по сети на все подключенные узлы. Проникновение и активация червя осуществляется, как правило, с использованием недоработок в защите операционной системы. Черви могут функционировать независимо и интенсивно распространяться. Для их работы не требуется ни активация, ни вмешательство человека. Ущерб от саморазмножающихся сетевых червей может значительно превышать последствия одного вируса. Черви способны быстро поражать значительную часть интернета.

Один из самых известных червей – червь Морриса, был написан студентом Робертом Моррисом в 1988 г. В течение трех дней вирусом было инфицировано 6200 машин, поражены основные вычислительные центры, составлявшие основу интернета, работа сети была парализована. Общие подсчитанные потери от червя составили около 100 млн. долларов. К расследованию было подключено ФБР. К счастью, червь, блокируя работу сети, не портил саму информацию. Однако незначительная логическая ошибка в коде программы, допущенная разработчиком, привела к разрушительным последствиям. Компьютеры заражались многократно, и каждый дополнительный экземпляр замедлял работу компьютера до состояния отказа от обслуживания, подчистую исчерпывая ресурсы компьютера. По характеру последствий данный случай

был расценен в США как национальная катастрофа. Результаты исследований действия вируса и выбора необходимых мер по ликвидации последствий были засекречены, публикации, посвященные этому случаю, прекратились.

«*Троянский конь*» – неразмножающаяся программа, представляющая собой инструмент для атаки, замаскированный под некоторую легитимную программу. Успешное выполнение троянского коня зависит от успешности его маскировки под программу, которую пользователь согласится запустить. Троянские кони могут быть сравнительно безвредными или могут содержать код, способный повредить файлы на жестком диске пользователя. Некоторые «троянские кони» также открывают *черный ход* (*backdoor*) в систему для злоумышленника.

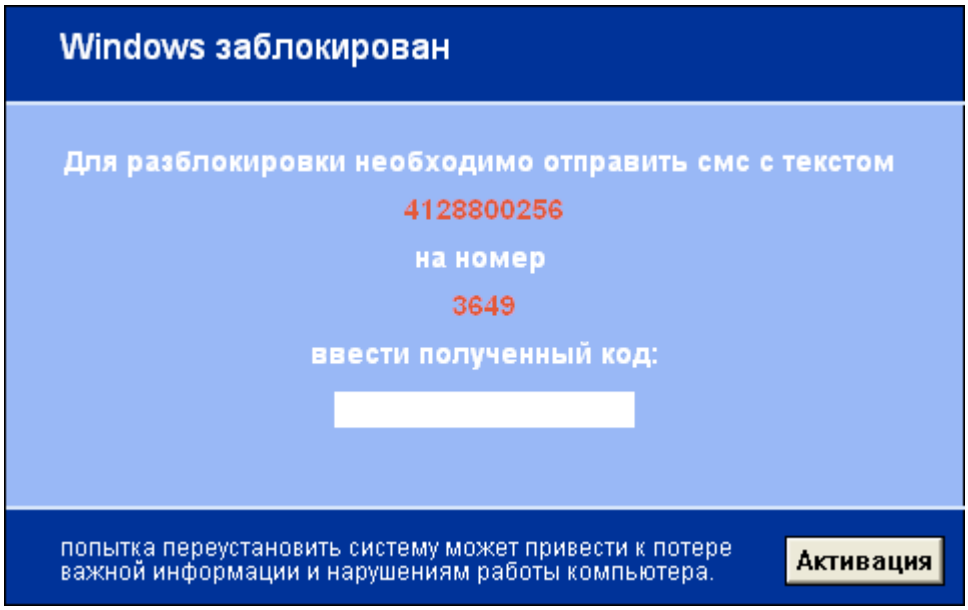

Рис. 1. Результат работы одного из распространенных «троянских коней». Программа требует заплатить за восстановление доступа к данным на компьютере

Отказ в обслуживании

В некоторых случаях злоумышленник заинтересован нарушить нормальное функционирование сети. Этот вид атак обычно выполняется с целью воспрепятствовать работе организации или сайта.

Отказ в обслуживании (*Denial of Service*, *DoS-атака*) – агрессивные атаки с отдельных компьютеров или групп компьютеров, препятствующие обслуживанию легитимных пользователей. *DoS*-атаки могут быть нацелены на пользовательские системы, серверы, маршрутизаторы и сетевые соединения.

Обычно *DoS*-атаки предполагают следующие вредоносные действия:

• насыщение системы или сети посторонним трафиком, блокирующим доставку легитимного трафика;

• нарушение соединения клиента с сервером для предотвращения доступа к сетевой службе.

Существует несколько видов *DoS*-атак. Администраторы, отвечающие за вопросы безопасности, должны знать о видах *DoS*-атак, которые угрожают их сетям, и обеспечить защиту сетей. Наиболее распространенными являются следующие.

• *Атака SYN* (затопление пакетами синхронизации) – к серверу направляется поток пакетов от клиента, запрашивающего установление соединения. Пакеты содержат неверные *IP*-адреса источников. Сервер, занятый обработкой этих фиктивных запросов, теряет способность обрабатывать легитимные запросы.

• *Ping of death* – устройству направляется пакет эхо-запроса, размер которого превышает максимум, предусмотренный протоколом *IP* (65 535 байт), что может привести к сбою системы-приемника.

• *Распределенная атака, вызывающая отказ в обслуживании* (*DDoS*-атака) – развитие *DoS*-атаки со значительно бóльшим вредоносным потенциалом. Цель также состоит в насыщении и переполнении сетевых каналов бесполезными данными, но *DDoS* действует в гораздо большем масштабе, чем простые *DoS*-атаки. Жертва обычно становится получателем громадного потока трафика от сотен тысяч источников атаки. Источниками могут быть компьютеры ничего не подозревающих пользователей, на которые ранее проникло вредоносное ПО, открывающее *DDoS*-атаку на целевой сайт после получения определенного сигнала.

Рис. 2. Архитектура *DDoS*-атаки

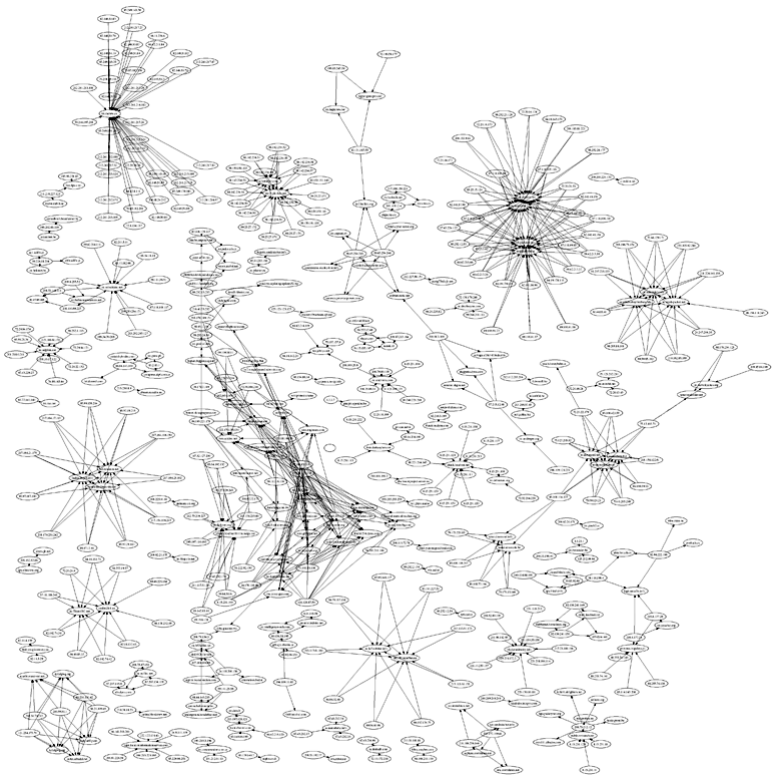

Рис. 3. Фрагмент *бот-нета TDL4*. *TDL4* распространяется с помощью вредоносной программы и применяет различные методы обхода защиты, а также шифрования при соединении с центром управления. Вирус имеет *руткит*-составляющую, которая позволяет скрывать присутствие любой вредоносной деятельности на компьютере. Ботнет существует с 2008 г. и постоянно развивается

Не все атаки, приводящие к нарушению работы сети, относятся к категории *DoS*. *Атака методом грубой силы* (англ. *brute force*, *брутфорс*) – другой распространенный вид атак, также часто приводящий к отказу в обслуживании. В этом случае используется быстродействующий компьютер для подбора паро-

лей или дешифровки. Злоумышленник активно перебирает большое число возможных вариантов для получения доступа или извлечения ключа шифрования. Атаки методом грубой силы могут стать причиной блокирования учетной записи пользователя или отказа обслуживания в результате перенасыщения трафиком определенного ресурса.

Шпионское ПО

Не все атаки ведут к ущербу или лишению легитимных пользователей доступа к ресурсам. Многие угрозы связаны со сбором сведений о пользователях, которые в дальнейшем могут использоваться для рекламы, маркетинга и анализа. Источниками таких угроз являются шпионское ПО, отслеживание файлов *cookie*, рекламное ПО и всплывающие окна. Не приводя к непосредственным сбоям в работе компьютера, они вторгаются в личные данные пользователя и могут раздражать своей работой.

К *шпионскому ПО* (*spyware*) относятся программы, собирающие личные данные с компьютера пользователя без его разрешения или ведома. Эти данные, в числе которых могут оказаться пароли и банковские реквизиты, поступают в распоряжение рекламных агентств или других пользователей интернета.

Шпионское ПО обычно устанавливается незаметно для пользователя при загрузке файла, установке другой программы или щелчке мышью во всплывающем окне. Оно может замедлить работу компьютера и изменить внутренние параметры настройки, сделав систему более уязвимой для других угроз. Кроме того, при удалении шпионского ПО часто возникают сложности.

Файлы cookie считаются одним из видов шпионского ПО, но не всегда являются вредоносными. Они фиксируют информацию о посещении сайтов определенным пользователем Интернета. Файлы *cookie* могут быть полезны для персонализации настроек и других применений, экономящих время. Многие веб-сайты при подключении пользователя требуют, чтобы файлы *cookie* были разрешены.

Рекламное ПО – вид шпионского ПО, предназначенный для сбора сведений о пользователях, посещающих веб-сайты. Собранные сведения в дальнейшем используются для целевой рекламы. Часто рекламное ПО попадает к пользователю вместе с «бесплатным» продуктом. Когда пользователь открывает окно веб-обозревателя, рекламное ПО может запустить новые копии обозревателя с рекламой продуктов и услуг, отражающей интересы пользователя в интернете. При этом нежелательные окна обозревателя могут открываться многократно и сильно затруднить работу в Интернете, особенно при низкоскоростном подключении.

Всплывающие и фоновые окна – виды рекламных окон, отображаемые на экране при посещении веб-сайта. В отличие от рекламного ПО, всплывающие и фоновые окна не служат для сбора сведений о пользователе и обычно связаны только с конкретным просматриваемым веб-сайтом. Но они могут раздражать и обычно рекламируют продукты и услуги, не представляющие интереса.

Спам

Рост значимости электронных коммуникаций сопровождается еще одним досаждающим явлением – несанкционированными массовыми рассылками по электронной почте. В некоторых случаях продавцы намеренно не прибегают к целевому маркетингу и стараются разослать рекламу товара или услуги по электронной почте максимальному числу получателей в расчете на то, что заинтересованный покупатель обязательно найдется. Этот широко распространенный подход к маркетингу в интернете получил название спама.

Спам представляет собой существенную угрозу для сети и ведет к перегрузке провайдеров интернета, серверов электронной почты и отдельных пользовательских систем. Лица и организации, ведущие рассылку спама, называются *спамерами*. Для рассылки спамеры часто пользуются незащищенными серверами электронной почты и сервисами мгновенного обмена сообщениями. Спамеры могут взламывать домашние компьютеры посредством таких прие-

мов, как вирусы, черви и троянские кони. После этого компьютеры начинают рассылать спам без ведома владельца.

В среднем каждый пользователь интернета получает более 3 000 спам-сообщений за год. Спам нагружает интернет-каналы и становится настолько серьезной проблемой, что во многих странах появились законы, регулирующие порядок проведения подобных рассылок.

Общие меры по безопасности

Риски безопасности невозможно полностью исключить или надежно предотвратить. Однако эффективное управление рисками и их оценка способны значительно снизить опасность существующих факторов. Для минимизации риска важно помнить, что полностью обезопасить организацию с помощью только одного продукта невозможно. Сетевая безопасность обеспечивается совокупностью продуктов и услуг в сочетании с тщательно проработанной и неукоснительно соблюдаемой политикой безопасности.

Политика безопасности – формальное изложение правил, которых должны придерживаться пользователи при доступе к технологическим и информационным ресурсам. Она может сводиться к простым правилам пользования или же может занимать сотни страниц с подробной детализацией правил подключения и пользования сетью. Политика безопасности должна обеспечить централизацию мер по защите, контролю, испытанию и развитию сети. В то время как большинство домашних пользователей обходятся без письменной политики безопасности, по мере расширения и укрупнения сети наличие четко определенной политики безопасности для всех пользователей приобретает все большую значимость. Существенные разделы политики безопасности:

- политика идентификации и аутентификации;
- политика применения паролей;
- политика целевого использования;
- политика удаленного доступа;
- порядок проработки инцидентов.

При всем при том разработанная политика безопасности будет эффективна только в том случае, если она будет поддерживаться и соблюдаться всеми пользователями сети.

Таким образом, политика безопасности должна обеспечить централизацию мер по защите, контролю, испытанию и развитию сети. Она реализуется с помощью процедур безопасности, которые регламентируют порядок настройки, регистрации пользователей, аудита и обслуживания узлов и сетевых устройств. К ним относятся как предварительные меры для снижения риска, так и активное противодействие известным угрозам безопасности. В состав процедур входят как простые и малозатратные операции (например, регулярное обновление версий ПО), так и сложные задачи создания межсетевых экранов и систем обнаружения вторжения.

Укрепление безопасности сети достигается, в частности, следующими средствами.

1. *Исправления и обновления ПО*. Одним из распространенных способов, к которому прибегает хакер для получения доступа к узлам и сетям, являются уязвимости в ПО. Важно использовать актуальные версии ПО, устанавливая текущие исправления для укрепления безопасности и обновления для нейтрализации угроз. *Исправление* – небольшой фрагмент кода, устраняющий определенную проблему. *Обновление*, в свою очередь, может не только содержать исправления ряда проблем, но и расширять программный пакет дополнительными функциональными возможностями.

Поставщики ОС (операционных систем: *Linux*, *Windows* и т.п.) и приложений, как правило, непрерывно выпускают обновления и исправления безопасности, устраняющие известные уязвимости ПО. Кроме того, поставщики часто выпускают т.н. *пакеты обновлений* – сборники исправлений и обновлений. Для удобства во многих операционных системах предусмотрена функция автоматического обновления с загрузкой обновлений ОС и приложений и установкой их на узел.

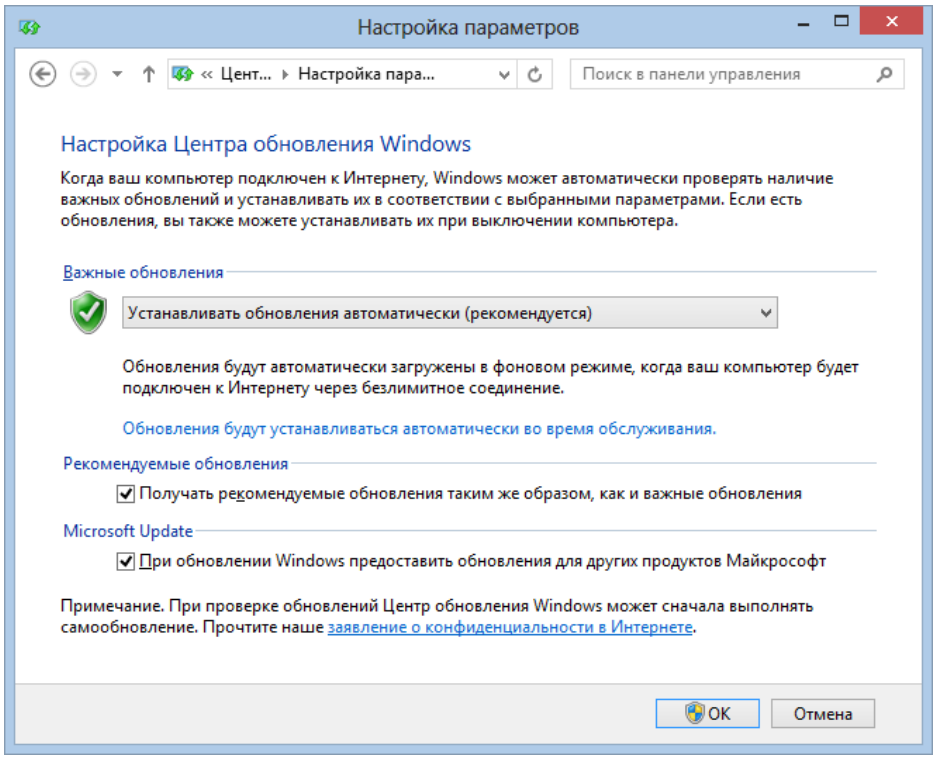

Рис. 4. Настройка обновления в Windows

2. *Антивирусная защита*. Даже с текущими обновлениями и исправлениями ОС и приложения остаются уязвимы для атак. Любое устройство, подключенное к сети, подвержено воздействию вирусов, червей и «троянских коней». Это вредоносное ПО может повреждать код операционной системы, ухудшать производительность компьютера, модифицировать приложения и уничтожать данные.

Присутствие вируса, червя или «троянского коня» часто можно опознать по ряду признаков:

- в работе компьютера происходят необъяснимые изменения;
- программа перестает реагировать на перемещение мыши и нажатие клавиш;
- программы самопроизвольно запускаются или прекращают работать;
- почтовая программа начинает рассылать большие объемы электронной почты;
- центральный процессор постоянно сильно загружен;
- возникают неопознанные процессы или сильно увеличивается число процессов;

• компьютер работает медленно или со сбоями.

Антивирусное ПО может использоваться как для профилактики, так и для реагирования. Оно предотвращает заражение, а также обнаруживает и удаляет вирусы, черви и «троянских коней». Антивирусное ПО должно быть установлено на всех компьютерах, подключенных к сети.

Как правило, современными антивирусными программами реализуются следующие функции:

• проверка электронной почты – сканирование входящей и исходящей электронной почты, выявление подозрительных вложений;

• динамическое сканирование в резидентном режиме – проверка исполняемых файлов и документов при обращении к ним;

• сканирование по графику – регулярное сканирование конкретных накопителей или всего компьютера на предмет вирусов по специально составленному графику;

• автоматическое обновление – проверка выхода и автоматическая загрузка описаний характеристик и признаков известных вирусов. Проверка выхода обновлений может осуществляться автоматически по графику.

Антивирусное ПО для удаления вируса должно знать его характеристики. Поэтому при выявлении вируса или признаков вируса важно сообщить об этом сетевому администратору. Это обычно делается в форме сообщения об инциденте согласно политике безопасности сети компании. Сетевые администраторы, в свою очередь, могут информировать о новых разновидностях угроз местные подразделения органов безопасности

3. *Защита от шпионского ПО*. Шпионское и рекламное ПО проявляет некоторые признаки, свойственные вирусам. Осуществляя несанкционированный сбор информации, они расходуют необходимые ресурсы компьютера и ухудшают производительность. Программы для защиты от шпионского ПО способны обнаруживать и удалять шпионские приложения, а также не допускать их установки в будущем. Многие средства защиты от шпионского ПО дополни-

тельно позволяют находить и удалять файлы *cookie*, а также рекламное ПО. Защита от шпионского ПО встроена в некоторые антивирусы.

4. *Средства блокирования спама* (*спам-фильтр*). Спам не только раздражает пользователей, но и ведет к перегрузкам серверов электронной почты, может являться носителем вирусов и создает другие угрозы безопасности. Кроме того, зачастую спамеры для получения контроля над узлом оставляют на нем код в форме вируса или «троянского коня». Зараженные узлы начинают рассылать спам без ведома владельца. Компьютер, зараженный подобным образом, называется *фабрикой спама*.

Программное обеспечение для защиты узлов от спама (*антиспам*) обнаруживает спам и нейтрализует его, например, путем удаления или помещения в папку для несанкционированных рассылок. Такое ПО может быть установлено локально на компьютере или на сервере электронной почты. Кроме того, многие провайдеры интернета предлагают услуги фильтрации спама. Однако ПО для защиты от спама неспособно распознать все виды спама, поэтому открывать поступившие сообщения всегда следует осторожно. Кроме того, иногда легитимные сообщения могут быть отнесены к спаму и обработаны соответствующим образом.

Одним из видов спама, часто пересылаемого пользователями друг другу, является предупреждение о вирусах. Иногда они имеют под собой почву, но чаще всего представляют собой ложные сообщения о несуществующих вирусах. Однако получатели, стараясь проинформировать других об опасности, начинают массово пересылать подобные сообщения и перегружать почтовую систему. Кроме того, сетевые администраторы могут потратить лишние силы и время на расследование проблемы, которой в действительности не существует. Наконец, многие сообщения действительно оказывают содействие распространению вирусов, червей и «троянских коней». Перед дальнейшей пересылкой сообщения с предупреждением о вирусе необходимо проверить, не является ли сообщение ложным, либо вовсе его проигнорировать.

5. *Средства блокирования всплывающих и фоновых окон*. Средство блокирования всплывающих окон по умолчанию встроено во многие обозреватели. Следует отметить, что некоторые программы и веб-страницы создают всплывающие окна, необходимые для взаимодействия с пользователем, которые не должны блокироваться. Для этого в большинстве средств блокировки предусмотрена функция отмены блокировки.

6. *Межсетевые экраны* – средство контроля входящего и исходящего трафика для данной сети.

Межсетевой экран

Помимо защиты отдельных компьютеров и серверов, подключенных к сети, необходимо контролировать прохождение трафика через сеть в различных направлениях.

Межсетевой экран (*брандмауэр*) представляет собой одно из наиболее эффективных средств безопасности, защищающее пользователей сети от внешних угроз. Межсетевой экран разделяет две сети или более и контролирует проходящий между ними трафик, одновременно предотвращая несанкционированный доступ. В межсетевых экранах используются различные методы определения разрешенного и запрещенного доступа к сети:

- *фильтрация пакетов* – запрет или разрешение доступа на основе *IP*- или *MAC*-адресов;
- *фильтрация по приложениям* – запрет или разрешение доступа для конкретного приложения на основе номеров портов;
- *фильтрация по URL* – запрет или разрешение доступа к веб-сайтам на основе конкретных URL-адресов или ключевых слов;
- *динамический анализ пакетов* (*SPI*) – входящие пакеты должны представлять собой легитимные отклики на запросы внутренних узлов. Незапрошенные пакеты блокируются, если они не разрешены в явном виде. *SPI* также позволяет распознавать и блокировать конкретные виды атак, например *DoS*.

Межсетевые экраны поддерживают один или несколько подобных механизмов фильтрации и блокирования. Кроме того, межсетевые экраны часто выполняют преобразование сетевых адресов (*NAT*). *NAT* преобразует внутренние адреса и группы адресов во внешние публичные адреса, используемые для пересылки по сети. При этом внутренние *IP*-адреса скрываются от внешних пользователей.

Решения для межсетевых экранов поставляются в различных формах:

• *аппаратный межсетевой экран* – выделенное устройство, называемое устройством защиты;

• *серверный межсетевой экран* – приложение межсетевого экрана, выполняемое в сетевой операционной системе (*NOS*), такой как *UNIX* или *Windows*;

• *интегрированный межсетевой экран* дополняет возможности существующего устройства (например, маршрутизатора) функциями межсетевого экрана;

• *персональный межсетевой экран* размещаются на конечном узле и не рассчитан на защиту локальной сети в целом. Он может быть реализован в ОС по умолчанию или установлен сторонним поставщиком.

Размещение межсетевого экрана в качестве пограничного устройства между внутренней сетью (интранетом) и интернетом позволяет контролировать весь исходящий и входящий *трафик* и управлять его прохождением. Между внутренней и внешней сетью создается четкий защитный рубеж. Однако некоторым внешним клиентам может потребоваться доступ к внутренним ресурсам. Для этого можно предусмотреть демилитаризованную зону (*DMZ*).

Демилитаризованная зона – военно-политический термин, означающий территорию между двумя сторонами конфликта, в которой запрещено военное присутствие. В компьютерных сетях демилитаризованной зоной называется участок сети, доступный как внутренним, так и внешним пользователям. Он более защищен по сравнению с внешней сетью, но менее защищен по сравнению с внутренней сетью. *DMZ* создается посредством одного или нескольких

межсетевых экранов, разграничивающих внутреннюю сеть, *DMZ* и внешнюю сеть. В *DMZ* часто размещаются веб-серверы, открытые для доступа извне.

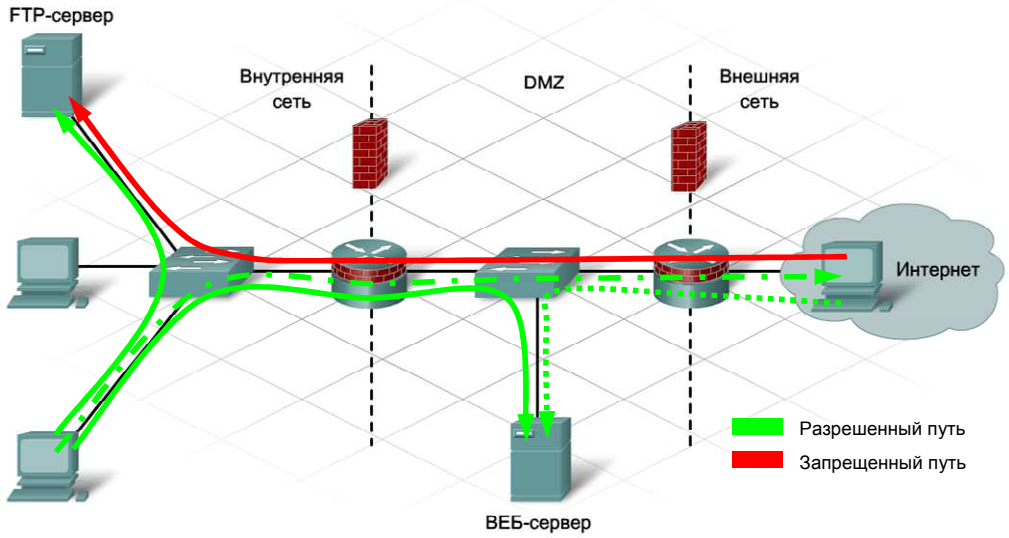

Рис. 5. Организация сети с двумя брандмауэрами с демилитаризованной зоной

Возможна организация сети с демилитаризованной зоной с двумя и с одним межсетевыми экранами.

В конфигурации с двумя межсетевыми экранами предусмотрены внутренний и внешний межсетевой экраны, между которыми располагается *DMZ*. Внешний межсетевой экран применяет менее строгие ограничения и разрешает доступ пользователей из интернета в *DMZ*, а также сквозное прохождение трафика, запрошенного внутренними пользователями. Внутренний межсетевой экран применяет более строгие ограничения и защищает внутреннюю сеть от несанкционированного доступа.

Если используется один межсетевой экран, то он делит сетевое пространство на три зоны: внешняя сеть, внутренняя сеть и *DMZ*. Весь трафик поступает на межсетевой экран из внешней сети. Межсетевой экран должен контролировать трафик и принимать решение о его пересылке в *DMZ* или во внутреннюю сеть, либо о запрете пересылки.

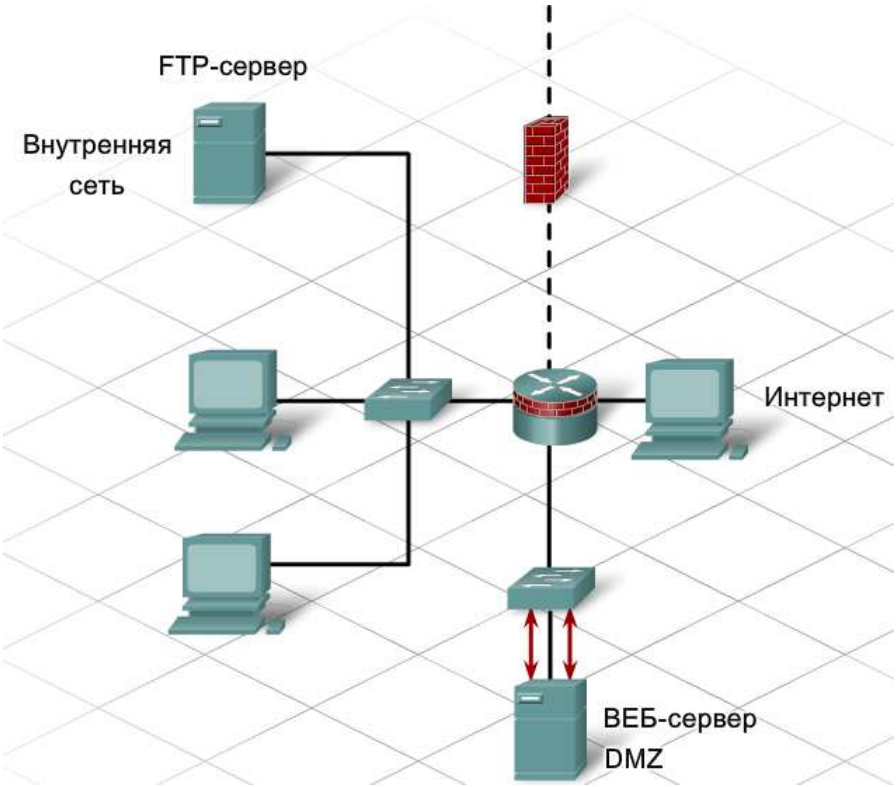

Рис. 6. Конфигурация сети с одним брандмауэром

Для небольших сетей с низким трафиком оптимальной является конфигурация на основе одного межсетевого экрана. Однако в некоторых случаях он может оказаться перегруженным. Конфигурация с двумя межсетевыми экранами целесообразна для крупных и сложных сетей со значительно бóльшими объемами трафика.

Во многих устройствах для домашних сетей, например интегрированных маршрутизаторах, часто имеются многофункциональные программные межсетевые экраны. Такие межсетевые экраны обычно реализуют преобразование сетевых адресов (*NAT*), динамический анализ пакетов (*SPI*), а также фильтрацию по *IP*-адресам, приложениям и веб-сайтам. Они также поддерживают функции *DMZ*.

Интегрированный маршрутизатор позволяет настроить простейшую *DMZ* для доступа к внутреннему серверу с узлов за пределами сети. Для этого сервер должен иметь статический *IP*-адрес, который указывается в конфигурации *DMZ*. Интегрированный маршрутизатор изолирует трафик, пересылаемый на указанный *IP*-адрес. Этот трафик пропускается только на тот порт коммутато-

ра, к которому подключен сервер. На все остальные узлы по-прежнему распространяется защита межсетевого экрана.

При активации *DMZ* в простейшем виде внешние узлы получают доступ ко всем портам сервера, например, **80** (**HTTP**), **21** (**FTP**) и **110** (**POP3** для электронной почты).

Функция переадресации портов позволяет настроить более строгую конфигурацию *DMZ*. В этом случае указываются порты, которые должны быть доступны на сервере. Пропускается только трафик, направленный на эти порты. Весь остальной трафик исключается.

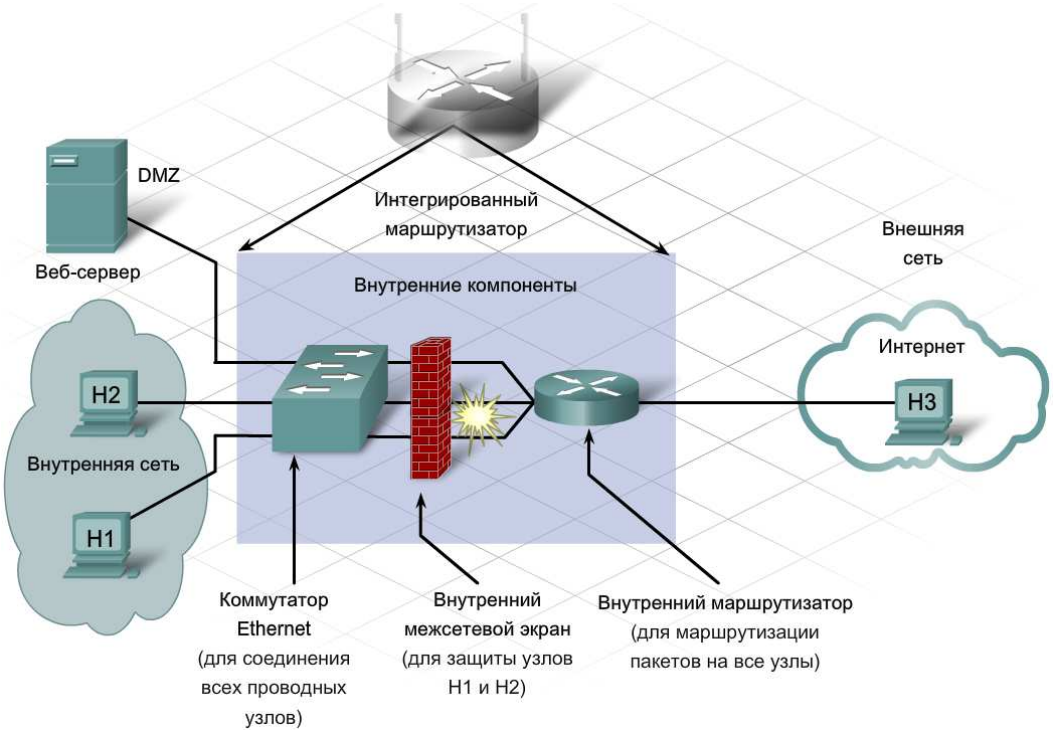

Рис. 7. Организация сети с использованием интегрированного маршрутизатора

Беспроводная точка доступа в составе интегрированного маршрутизатора часто считается частью внутренней сети. Необходимо понимать, что при работе точки доступа в незащищенном режиме все подключившиеся к ней пользователи получают доступ к внутренней защищенной сети без прохождения межсетевого экрана. Злоумышленники могут таким образом получить доступ к внутренней сети, минуя все средства защиты.

Уязвимости

Существует множество средств анализа уязвимостей для контроля безопасности узлов и сети. Такие средства называются *сканерами* и помогают определить потенциальные цели атак, а также спланировать необходимые меры. Средства анализа уязвимостей, предлагаемые разными поставщиками, существенно различаются по функциональным возможностям, но наиболее распространены функции, помогающие определить следующие параметры:

- число узлов, доступных в сети;
- сетевые службы, реализуемые узлами;
- наименования и версии операционных систем, установленных на узлах;
- используемые фильтры пакетов и межсетевые экраны.

Одним из популярных средств для анализа основных элементов защиты сети является *Microsoft Baseline Security Analyzer* (*MBSA*). *MBSA* специально разработан для выявления потенциальных проблем нарушения безопасности, связанных с операционными системами, обновлениями и приложениями корпорации Майкрософт. Он также выявляет ненужные службы, которые, возможно, запущены на компьютере, а также все открытые порты. MBSA запускается в системах *Windows Server* или *Windows XP* и используется для поиска распространенных ошибок при настройке системы безопасности или отсутствующих обновлений безопасности для операционной системы, а также для большинства версий *Internet Information Server* (*IIS*), *SQL Server*, *Internet Explorer* (*IE*) и прочих продуктов *Microsoft*. При этом *MBSA* предлагает конкретные способы устранения потенциальных проблем.

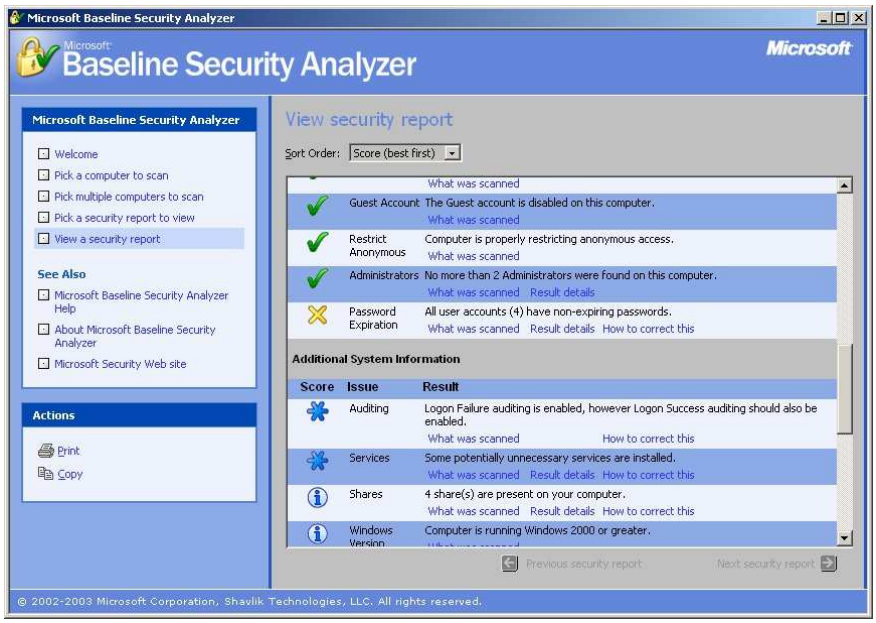

Рис. 8. Средство для анализа основных элементов защиты сети *MBSA*

При решении вопросов снижения существующих рисков необходимо придерживаться следующих правил:

- разработайте политики безопасности;
- обеспечьте физическую охрану серверов и сетевого оборудования;
- настройте полномочия входа в систему и доступа к файлам;
- своевременно обновляйте операционную систему и приложения;
- изменяйте настройки по умолчанию, если они недостаточно строги;
- пользуйтесь средствами защиты от вирусов и шпионского ПО;
- обновляйте антивирусное ПО;
- активируйте средства, доступные в обозревателе: блокировка всплывающих окон, защита от фишинга, контроль подключаемых модулей;
- используйте межсетевой экран.

Первый шаг в укреплении безопасности сети – *характеризация трафика* и выявление существующих угроз и уязвимостей. Даже полностью реализовав меры по защите сети, быть уверенным в ее безопасности можно только при непрерывном контроле. Меры и средства обеспечения безопасности требуют постоянного критического анализа в свете эволюции угроз.

Практическая часть

1. Откройте топологию корпоративной сети (интранета), разработанную Вами при выполнении предыдущей лабораторной работы. Перейдите к сегменту «Филиал в Казани».

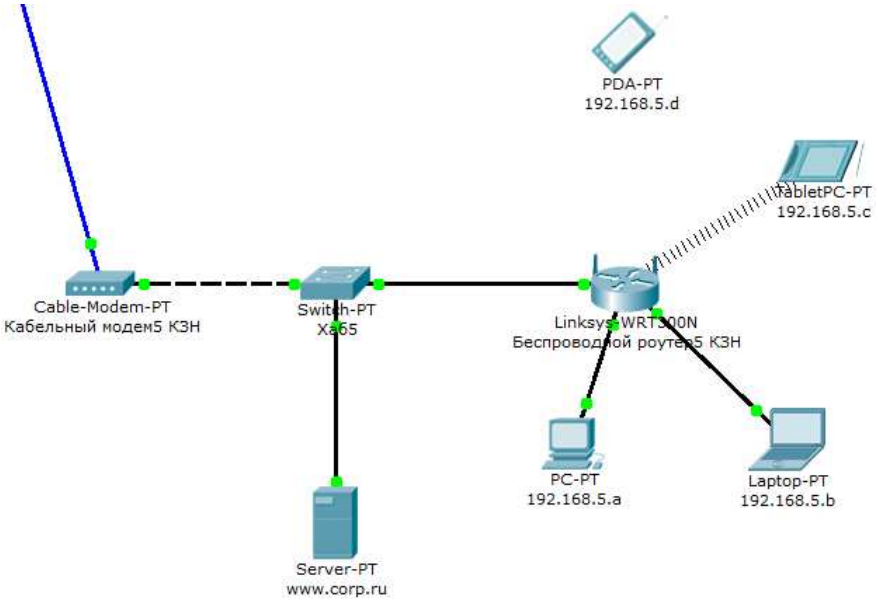

Рис. 9. Сегмент «Филиал в Казани»

2. Настройте ограничения доступа в интернет на основе *IP*-адреса. Для этого на главном экране многофункционального устройства щелкните вкладку *Access Restrictions* (ограничения доступа) и задайте параметр **`Access Policy 1`** (политика доступа 1). Введите в качестве названия политики **`Block-IP`** (блокировка *IP*). Выберите **`Enabled`** (включено), чтобы включить политику, а затем выберите **`Deny`** (запретить), чтобы предотвратить доступ в интернет с указанного *IP*-адреса.

Рис. 10. Настройка ограничений доступа

3. Щелкните кнопку *Edit List* (редактировать список) и введите *IP*-адрес узла-B. Щелкните *Save Settings* (сохранить настройки), а затем *Close* (закрыть). Щелкните *Save Settings* (сохранить настройки)» для сохранения политики доступа **`Block-IP`**.

4. Протестируйте политику, попробовав подключиться к внешнему веб-серверу с узла **`192.168.5.b`**. Откройте обозреватель и введите *IP*-адрес внешнего сервера в поле адреса. Проанализируйте, как ведут себя *HTTP*-пакеты в этом случае.

5. Измените статус политики **`Block-IP`** на **`Disabled`** (выключено) и щелкните *Save Settings*. Как изменится функционирование сети? Проверьте так же, как указано в предыдущем пункте.

6. Настройте зону *DMZ*. Для начала добавьте внутрь сегмента сервер **`www.filial5.ru`**, настройте *DHCP Reservation* на выдачу ему статического адреса **`192.168.0.130`**. В настройках *HTTP*-сервера задайте следующее содержимое страницы index.html: **`<html><h1>Welcome to FILIAL5!</h1></html>`**. Этот компьютер будет выполнять функцию сервера *DMZ*.

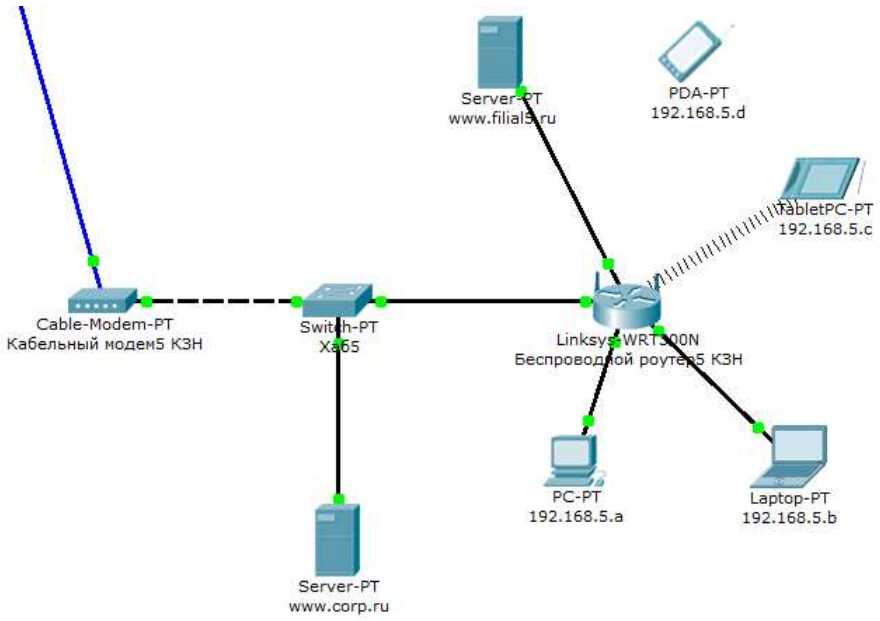

Рис. 11. Сегмент «Филиал в Казани»

7. На главном экране графического интерфейса пользователя *Беспроводного роутера5* выберите вкладку *Applications & Gaming* (приложения и игры) и щелкните *DMZ*. По умолчанию функция *DMZ* отключена. Включите ее. В поле *Destination IP Address* (*IP*-адрес назначения) введите *IP*-адрес сервера *DMZ*. Щелкните *Save Settings* для сохранения конфигурации.

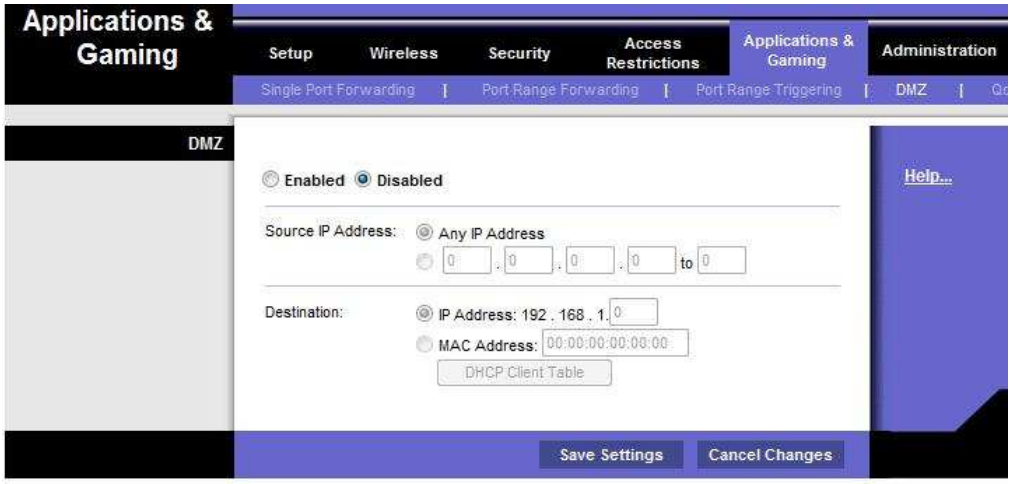

Рис. 12. Настройка демилитаризованной зоны

8. Протестируйте *HTTP*-доступ к серверу *DMZ*: откройте обозреватель на внешнем компьютере (например, **`www.corp.ru`**) и введите внешний *IP*-адрес многофункционального устройства. Попробуйте сделать то же самое из обозревателя на компьютере **`192.168.5.b`**, используя как внешний, так и внутренний адрес. Объясните увиденное.

9. Настройте *DNS*-сервер на узле **`200.200.200.230`** таким образом, чтобы он отдавал соответствующий *IP*-адрес для сайта **`www.filial5.ru`**.

Контрольные вопросы

1. Дайте классификацию сетевых угроз.
2. Какие бывают источники вторжения в сеть и что является причиной их существования?
3. Что такое социотехника? Какую роль играет социотехника в организации безопасности функционирования интранета?
4. Приведите классификацию социотехник. Применимы ли разновидности социотехники в других областях человеческой деятельности?
5. Дайте классификацию вредоносного программного обеспечения и объясните разницу между приведенными типами. Как можно определить, что компьютер стал жертвой такого ПО?
6. Что такое отказ в обслуживании? Что может стать причиной этого явления?
7. Объясните, что представляет собой распределенный отказ в обслуживании. Что является источником такой ситуации? Что такое *ботнет*?
8. Объясните, в чем суть брут-форса. Где еще можно применять эту технику взлома?
9. Перечислите категории шпионского программного обеспечения.
10. Что такое политика безопасности?
11. Каким образом предотвратить заражение вредоносным ПО? Излечить компьютер от такого ПО?
12. Что такое спам? Что является источником спама? Каким образом спам распространяется по сети? Как уменьшить его отрицательное влияние?
13. Что такое межсетевой экран? Как он действует?
14. Объясните целесообразность объявления демилитаризованной зоны.
15. Какие бывают сетевые уязвимости и как их уменьшить или избежать?